

HỌC VIỆN NGÂN HÀNG
KHOA CÔNG NGHỆ THÔNG TIN & KINH TẾ SỐ



CHƯƠNG III

CÁC DẠNG TẤN CÔNG

&

PHẦN MỀM ĐỘC HẠI

Nội dung

3.1

Khái quát về mối đe dọa và tấn công

3.2

Các công cụ hỗ trợ tấn công

3.3

Các dạng tấn công thường gặp

3.4

Những xu hướng tấn công mới gây mất an toàn và bảo mật thông tin

3.1. Khái quát về mối đe dọa và tấn công

- ❖ **Mối đe dọa:**
- ❖ **Các điểm yếu:**
- ❖ **Lỗ hổng bảo mật:**
- ❖ **Tấn công:**

$$\text{Tấn công} = \text{Mối đe dọa} + \text{Lỗ hổng}$$

3.2. Các công cụ hỗ trợ tấn công

- ❖ Công cụ rà quét lỗ hổng, điểm yếu hệ thống
- ❖ Công cụ quét cổng dịch vụ:
- ❖ Công cụ nghe trộm
- ❖ Công cụ ghi phím gõ:

3.3. Các dạng tấn công thường gặp

3.3.1 Tấn công vào mật khẩu

- ❖ Định nghĩa: Là dạng tấn công nhằm đánh cắp mật khẩu và thông tin tài khoản người dùng
- ❖ Các dạng:
 - ❑ Tấn công dựa trên từ điển
 - ❑ Tấn công vét cạn

3.3. Các dạng tấn công thường gặp

❖ Phòng chống

- ❑ Chọn mật khẩu đủ mạnh:
- ❑ Định kỳ thay đổi mật khẩu:
- ❑ Mật khẩu không lưu ở dạng rõ, nên lưu dạng mã hóa
- ❑ Hạn chế trao đổi tên người dùng và mật khẩu trên kênh truyền không được mã hóa

3.3. Các dạng tấn công thường gặp

3.3.2 Tấn công bằng mã độc

- ❖ **Định nghĩa:** Là dạng tấn công sử dụng các mã độc làm công cụ để tấn công hệ thống nạn nhân
- ❖ **Các dạng:**
 - ❑ Khai thác các lỗ hổng về lập trình, cấu hình hệ thống để chèn và thực hiện mã độc: Khai thác lỗi tràn bộ đệm; khai thác lỗi không kiểm tra đầu vào, tấn công chèn mã SQL và tấn công sử dụng mã script, kiểu XSS, CSRF.
 - ❑ Lừa người sử dụng tải, cài đặt và thực hiện các phần mềm độc hại

3.3. Các dạng tấn công thường gặp

3.3.2.1 Tấn công khai thác lỗi tràn bộ đệm

❖ Lỗi tràn bộ nhớ đệm:

- ❑ Là một trong các lỗi thường gặp trong các HĐH và đặc biệt nhiều ở phần mềm U'D
- ❑ Xảy ra khi một U'D cố gắng ghi dữ liệu vượt khỏi phạm vi của bộ nhớ đệm.

❖ Nguyên nhân việc tràn bộ nhớ đệm: do người lập trình không kiểm tra hoặc kiểm tra không đầy đủ các dữ liệu đầu vào

3.3. Các dạng tấn công thường gặp

❖ Khai thác lỗi tràn bộ đệm:

- ❑ Tin tặc gửi mã độc dưới dạng dữ liệu đến ứng dụng nhằm ghi đè, thay thế địa chỉ trở về với mục đích tái định hướng chương trình đến thực hiện đoạn mã độc
- ❑ Tin tặc thường phải thực hiện việc gỡ rối (debug) chương trình và nắm chắc cơ chế gây lỗi và phương pháp quản lý, cấp phát vùng nhớ ngăn xếp của ứng dụng

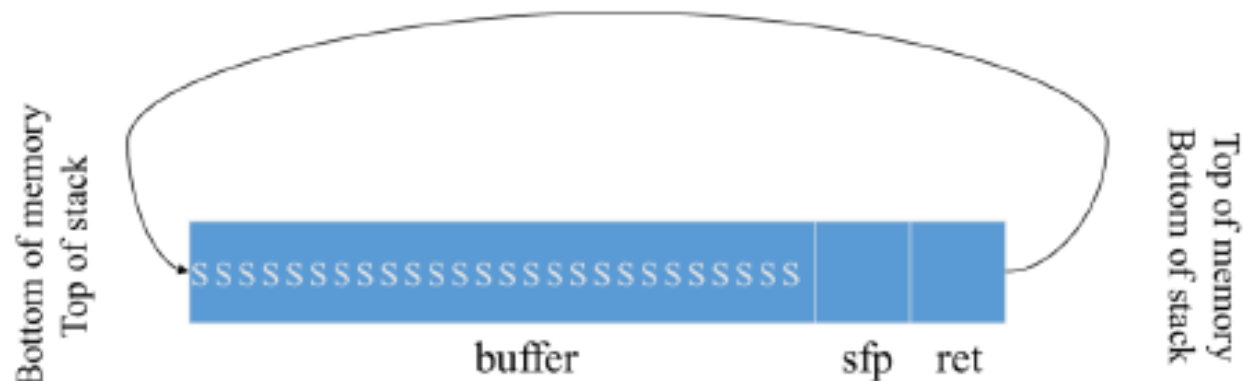
3.3. Các dạng tấn công thường gặp

```
jmp     0x1F
popl    %esi
movl    %esi, 0x8(%esi)
xorl    %eax, %eax
movb    %eax, 0x7(%esi)
movl    %eax, 0xC(%esi)
movb    $0xB, %al
movl    %esi, %ebx
leal    0x8(%esi), %ecx
leal    0xC(%esi), %cdx
int     $0x80
xorl    %ebx, %ebx
movl    %ebx, %eax
inc     %eax
int     $0x80
call    -0x24
.string "/bin/sh"
```

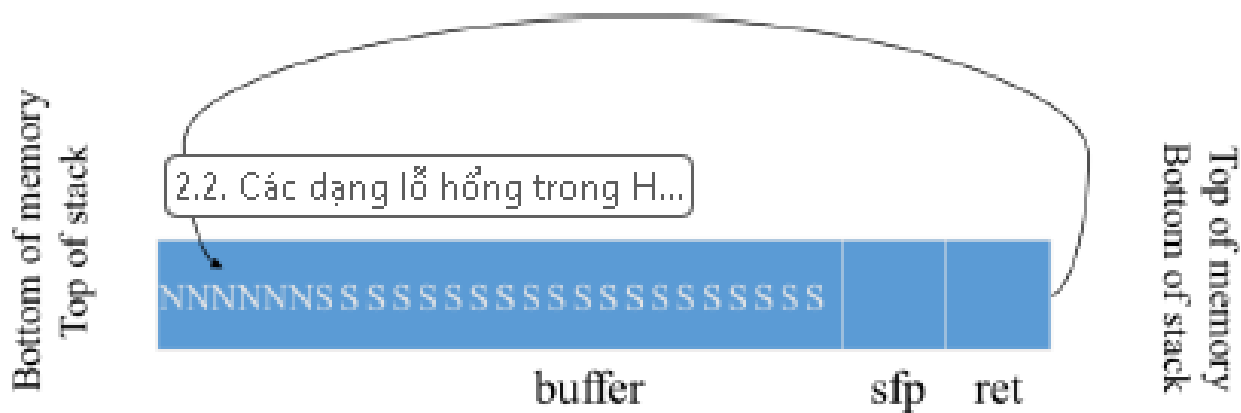
```
char shellcode[] =
"\xeb\x1f\x5e\x89\x76\x08\x31\xc0\x88\x46\x07\x89"
"\x46\x0c\xb0\x0b\x89\xf3\x8d\x4e\x08\x8d\x56\x0c"
"\xcd\x80\x31\xdb\x89\xd8\x40\xcd\x80\xe8\xdc\xff"
"\xff\xff/bin/sh";
```

Shellcode viết bằng hợp ngữ và chuyển thành chuỗi tấn công

3.3. Các dạng tấn công thường gặp

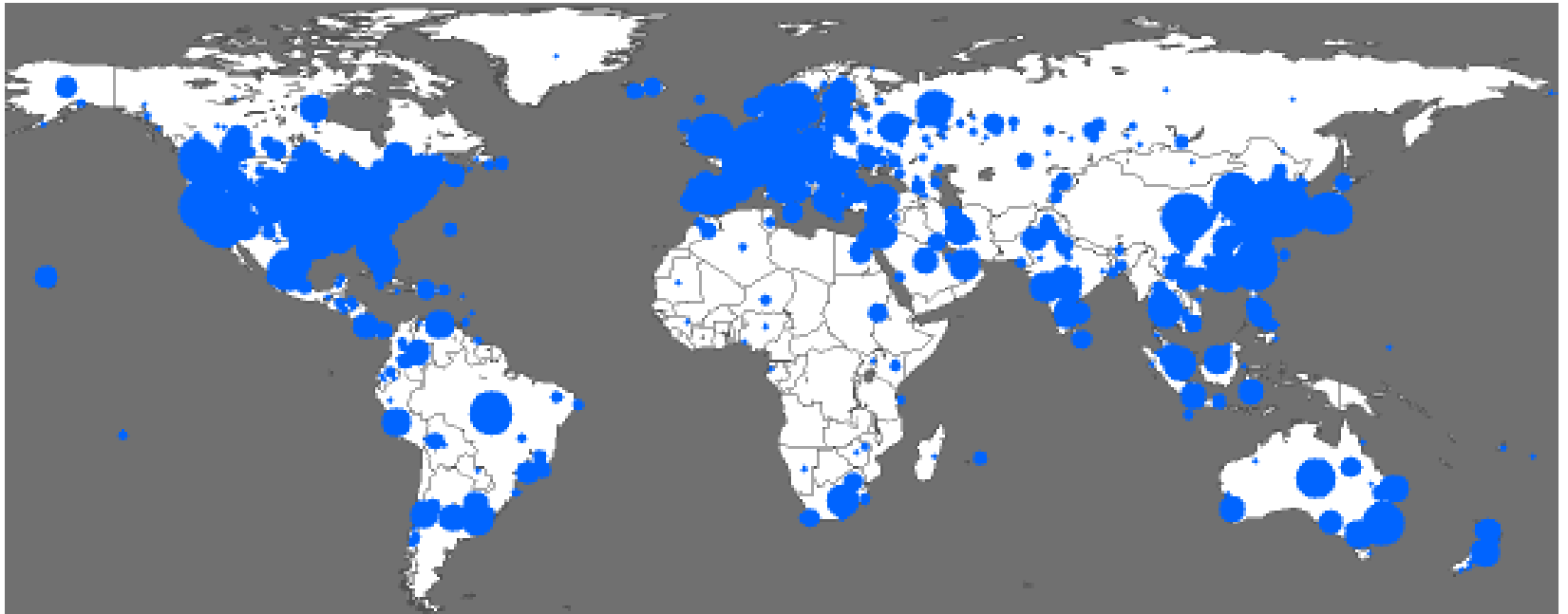


Chèn và thực hiện shellcode khai thác lỗi tràn bộ đệm



Chèn Shellcode với phần đệm bằng lệnh NOP(N)

Ví dụ: Sâu SQL Slammer



Bản đồ lây nhiễm sâu Slammer (màu xanh) theo trang www.caida.org vào ngày 25/1/2003 lúc 6h00 (giờ UTC) với 74.855 máy chủ bị nhiễm

3.3. Các dạng tấn công thường gặp

❖ Phòng chống

- ❑ Kiểm tra thủ công mã nguồn hay sử dụng các công cụ phân tích mã tự động
- ❑ Sử dụng cơ chế không cho phép thực hiện mã trong dữ liệu DEP (Data Execution Prevention):
- ❑ Ngẫu nhiên hóa sơ đồ địa chỉ cấp phát các ô nhớ trong ngăn xếp khi thực hiện chương trình
- ❑ Sử dụng các cơ chế bảo vệ ngăn xếp
- ❑ Sử dụng các ngôn ngữ, thư viện và công cụ lập trình an toàn

3.3. Các dạng tấn công thường gặp

3.3.2.2 Tấn công khai thác lỗi không kiểm tra đầu vào

❖ Lỗi không kiểm tra đầu vào:

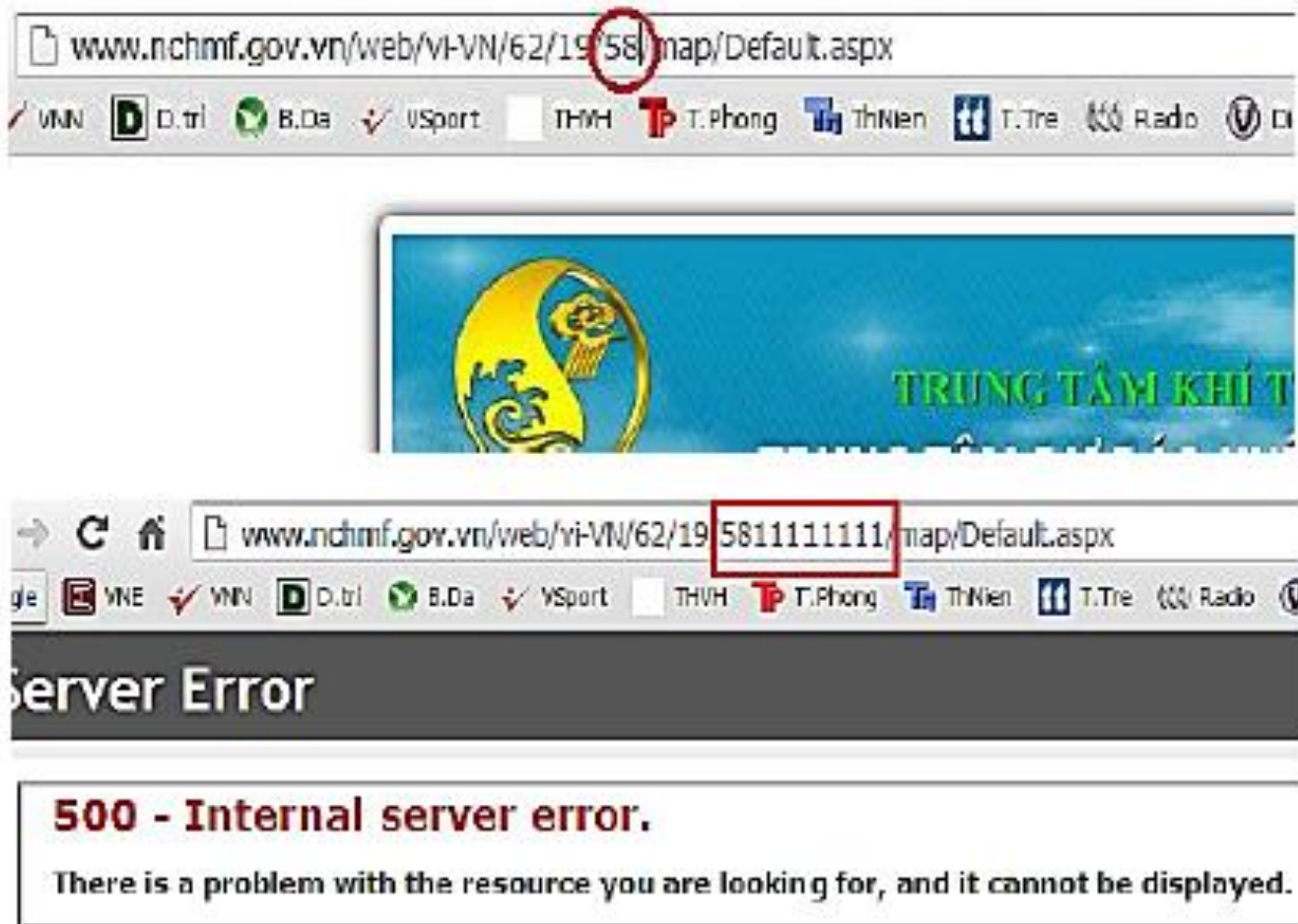
- ❑ Là lỗ hổng trong đó ứng dụng không kiểm tra, hoặc kiểm tra không đầy đủ các dữ liệu đầu vào
- ❑ Các dạng dữ liệu đầu vào điển hình:
 - Các trường dữ liệu văn bản
 - Các lệnh được truyền qua địa chỉ URL
 - Các file âm thanh, hình ảnh, đồ họa do người dùng hoặc các tiến trình khác cung cấp
 - Các đối số đầu vào trong dòng lệnh
 - Các dữ liệu từ mạng hoặc từ các nguồn không tin cậy

3.3. Các dạng tấn công thường gặp

❖ Tấn công khai thác:

- ❑ Dạng 1: Cung cấp dữ liệu quá lớn hoặc sai định dạng để gây lỗi cho ứng dụng
- ❑ Dạng 2: Chèn mã khai thác vào dữ liệu đầu vào để thực hiện trên hệ thống của nạn nhân

3.3. Các dạng tấn công thường gặp



Dạng 1:

3.3. Các dạng tấn công thường gặp

"SELECT * FROM tbl_products WHERE product_name like '%' + keyword + '%"

"SELECT * FROM tbl_products WHERE product_name like '%iPhone 7%"

"SELECT * FROM tbl_products WHERE product_name like '%iPhone 7';*DELETE FROM tbl_products;--%*"

Dạng 2:

3.3. Các dạng tấn công thường gặp

- ❖ **Phòng chống: Biện pháp chủ yếu là lọc dữ liệu đầu vào**
 - ❑ Kiểm tra kích thước và định dạng dữ liệu đầu vào
 - ❑ Kiểm tra sự hợp lý của nội dung dữ liệu
 - ❑ Tạo ra các bộ lọc để lọc bỏ các ký hiệu đặc biệt và các từ khóa mà kẻ tấn công có thể sử dụng như: *, =,--, SELECT, INSERT,...

3.3. Các dạng tấn công thường gặp

3.3.3 Tấn công từ chối dịch vụ và từ chối dịch vụ phân tán

3.3.3.1. Tấn công từ chối dịch vụ (DoS)

❖ **Định nghĩa:** là dạng tấn công nhằm ngăn chặn người dùng hợp pháp truy cập các tài nguyên mạng

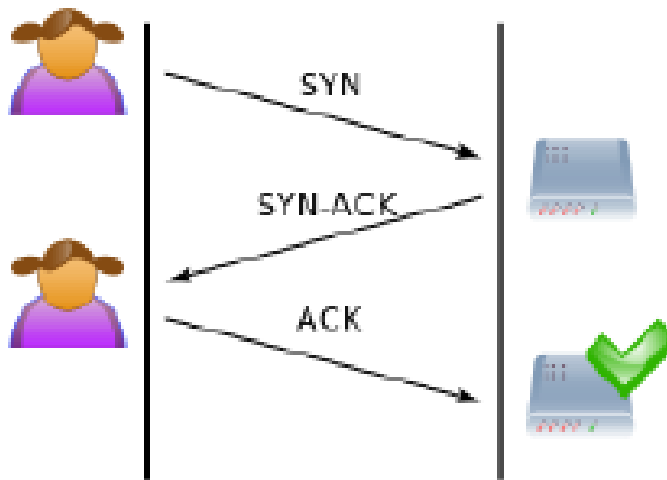
❖ **Các dạng:**

- ❑ **Tấn công logic:** là dạng tấn công khai thác các lỗi phần mềm làm dịch vụ ngừng hoạt động hoặc giảm hiệu năng
- ❑ **Tấn công gây ngập lụt:** Kẻ tấn công gửi một lượng lớn yêu cầu gây cạn kiệt tài nguyên

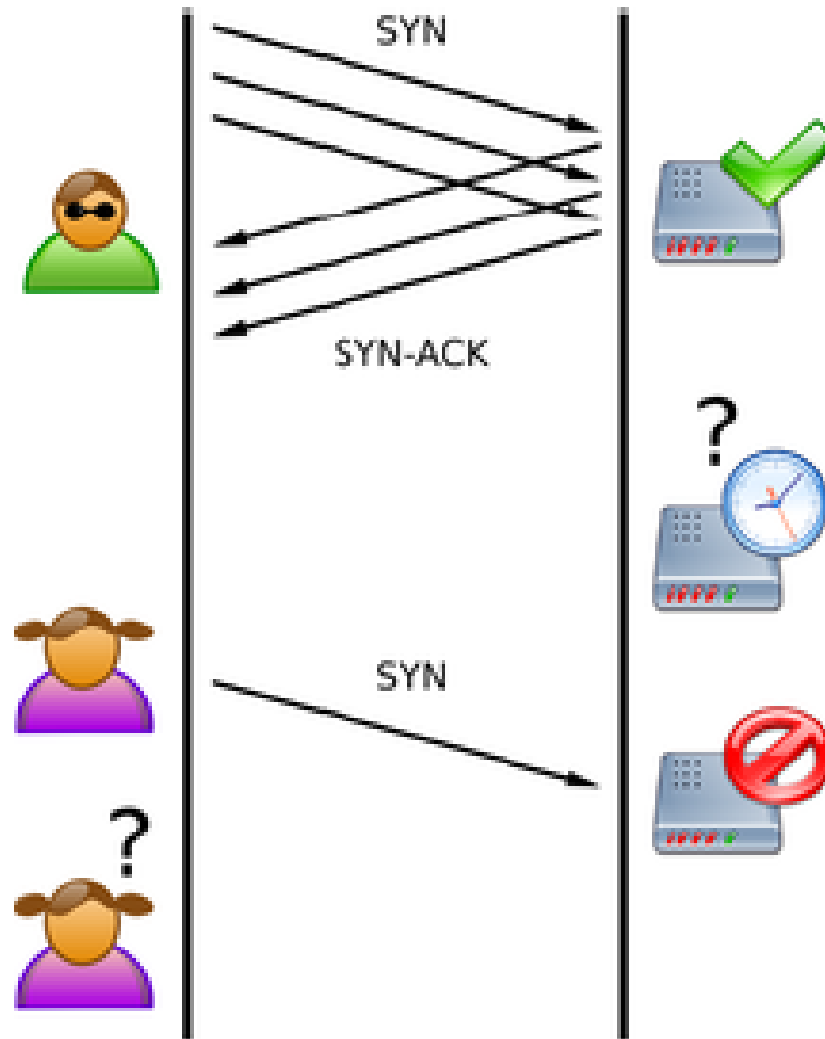
3.3. Các dạng tấn công thường gặp

❖ Các kỹ thuật tấn công:

- ❑ Tấn công SYN flood: Khai thác điểm yếu trong bắt tay 3 bước:



3.3. Các dạng tấn công thường gặp



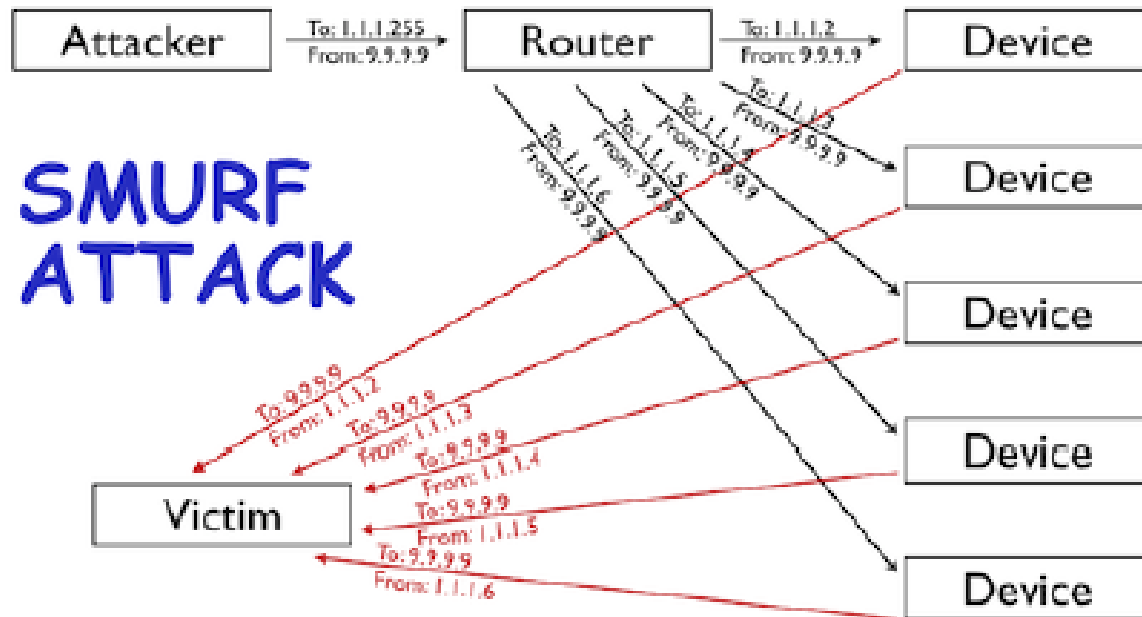
3.3. Các dạng tấn công thường gặp

Phòng chống: Chưa có giải pháp nào ngăn chặn triệt để, cần kết hợp các biện pháp sau:

- ✓ Sử dụng kỹ thuật lọc địa chỉ giả mạo
- ✓ Tăng kích thước Bảng kết nối
- ✓ Giảm thời gian chờ
- ✓ SYN cache
- ✓ Sử dụng tường lửa và Proxy

3.3. Các dạng tấn công thường gặp

- ❑ Tấn công Smurf: Sử dụng giao thức điều khiển truyền ICMP và kiểu phát quảng bá có định hướng để gây ngập lụt



3.3. Các dạng tấn công thường gặp

Phòng chống:

- ✓ Cấu hình các máy trong mạng và router không trả lời các yêu cầu ICMP hoặc các yêu cầu phát quảng bá
- ✓ Cấu hình các router không chuyển tiếp các yêu cầu ICMP gửi đến các địa chỉ quảng bá
- ✓ Sử dụng tường lửa để lọc các gói tin với địa chỉ giả mạo địa chỉ trong mạng

3.3. Các dạng tấn công thường gặp

3.3.3.2. Tấn công từ chối dịch vụ phân tán (DDoS)

- ❖ **Định nghĩa:** là một loại DoS liên quan đến việc gây ngập lụt các máy nạn nhân với một lượng rất lớn các yêu cầu kết nối giả mạo
- ❖ **Các dạng:**
 - ❑ **Tấn công DDoS trực tiếp:** Các yêu cầu tấn công được các máy tấn công gửi trực tiếp đến máy nạn nhân
 - ❑ **Tấn công DDoS gián tiếp:** Các yêu cầu tấn công được gửi đến cá máy phản xạ và sau đó gián tiếp chuyển đến máy nạn nhân

3.3. Các dạng tấn công thường gặp

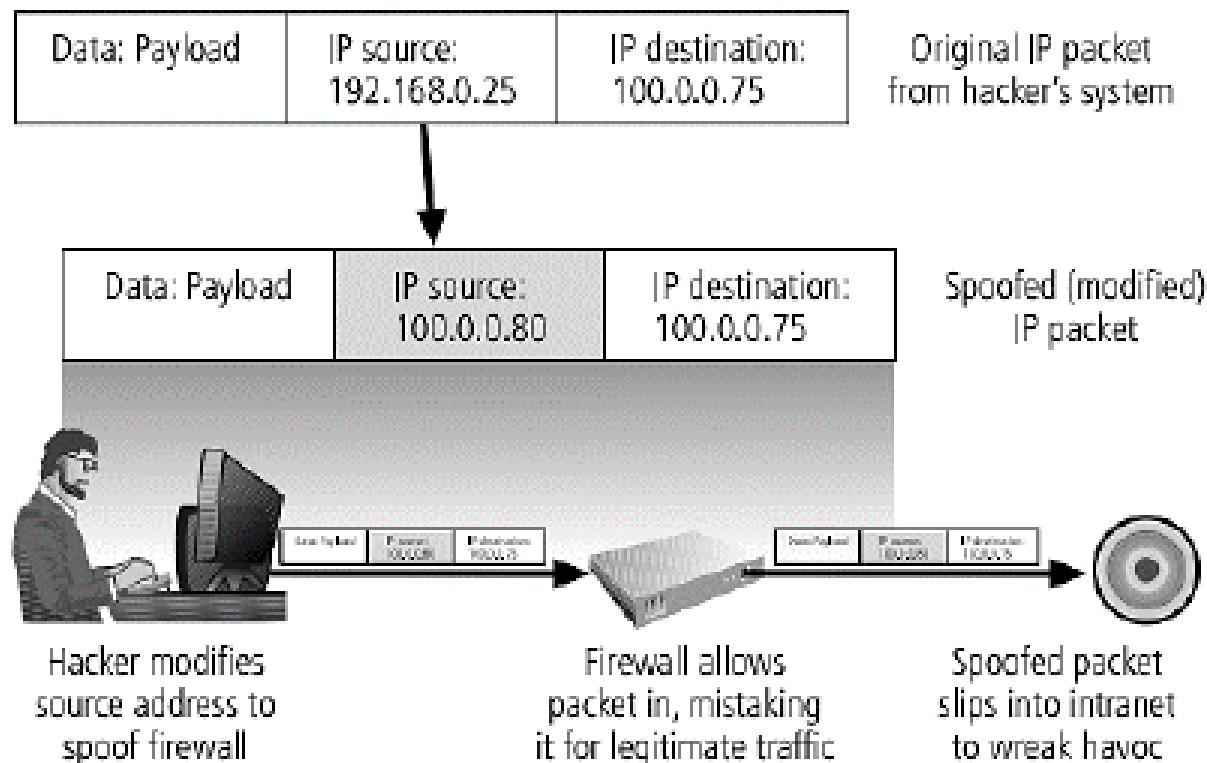
Phòng chống:

- ✓ Sử dụng các phần mềm rà quét virus và các phần mềm độc hại
- ✓ Sử dụng các hệ thống lọc đặt trên các router, tường lửa của các nhà cung cấp dịch vụ Internet
- ✓ Sử dụng các hệ thống giám sát, phát hiện bất thường nhằm phát hiện sớm các dấu hiệu
- ✓ Sử dụng tường lửa để chặn tạm thời các cổng dịch vụ bị tấn công

3.3. Các dạng tấn công thường gặp

3.3.4 Tấn công giả mạo địa chỉ

❖ Thường gặp nhất là giả mạo địa chỉ IP

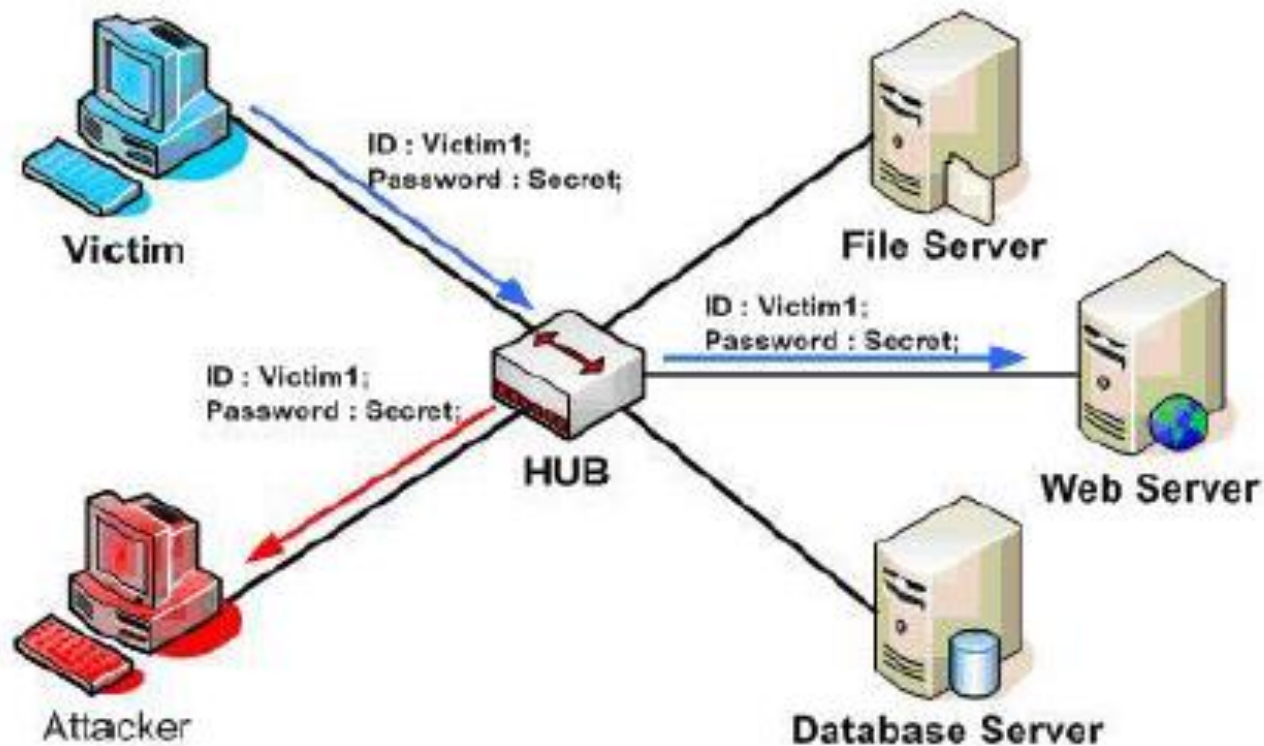


3.3. Các dạng tấn công thường gặp

Phòng chống: Biện pháp phòng chống tấn công giả mạo địa chỉ IP hiệu quả nhất là sử dụng kỹ thuật lọc trên tường lửa, hoặc các router với nguyên tắc lọc: các gói tin từ mạng ngoài đi vào mạng LAN mà có địa chỉ nguồn là địa chỉ nội bộ của mạng LAN đó thì chúng là các gói tin giả mạo và phải bị chặn

3.3. Các dạng tấn công thường gặp

3.3.5 Tấn công nghe lén



3.3. Các dạng tấn công thường gặp

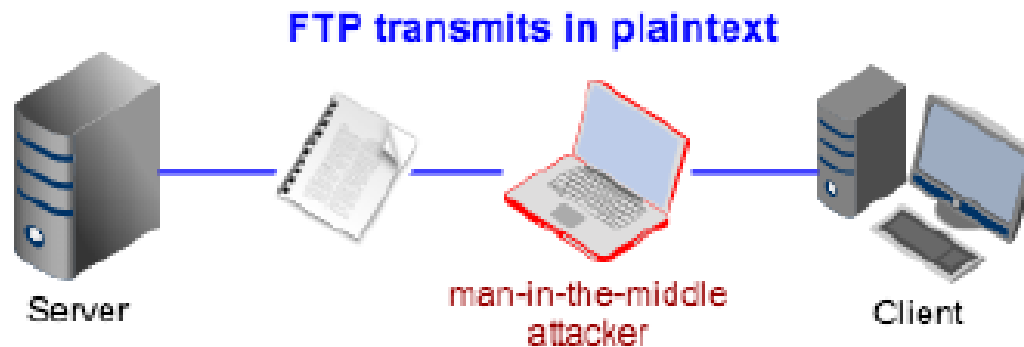
Phòng chống:

- ✓ Có cơ chế bảo vệ các thiết bị mạng và hệ thống truyền dẫn ở mức vật lý
- ✓ Sử dụng các biện pháp, cơ chế xác thực người dùng đủ mạnh
- ✓ Sử dụng các biện pháp bảo mật thông tin truyền dựa trên các kỹ thuật mã hóa

3.3. Các dạng tấn công thường gặp

3.3.6 Tấn công kiểu người đứng giữa

- ❖ Định nghĩa: là dạng tấn công dựa trên quá trình chuyển gói tin đi qua nhiều trạm thuộc các mạng khác nhau, và kẻ tấn công chặn bắt các thông điệp giữa 2 bên và chuyển thông điệp lại cho bên kia



3.3. Các dạng tấn công thường gặp

Phòng chống: Một trong các biện pháp hiệu quả để phòng chống tấn công kiểu người đứng giữa là hai bên tham gia truyền thông phải có cơ chế xác thực thông tin nhận dạng của nhau và xác thực tính toàn vẹn của các thông điệp trao đổi.

3.3. Các dạng tấn công thường gặp

3.3.7 Tấn công bằng bom thư và thư rác

- ❖ Định nghĩa: là một dạng tấn công DoS khi kẻ tấn công gửi một lượng rất lớn email đến hộp thư nạn nhân
- ❖ Các thủ thuật:
 - ❑ Gửi bom thư bằng cách sử dụng kỹ thuật xã hội, đánh lừa người dùng phát tán email
 - ❑ Khai thác lỗi trong hệ thống gửi nhận email SMTP
 - ❑ Lợi dụng các máy chủ email không được cấu hình tốt để gửi email (relay) cho chúng

3.4. Những xu hướng tấn công mới gây mất an toàn thông tin

ĐÂY LÀ MỘT TRONG CÁC CHỦ ĐỀ BÀI TẬP LỚN



Thank You !